Entrega 3 · Documento 1

Resultados de pruebas funcionales

Pruebas de los casos de uso del sistema, ejecutadas a través del WAF

Sistema integrado de eventos laborales (JML)

Andina Servicios S.A.S. (empresa ficticia · datos ficticios)

Politécnico Grancolombiano · Gerencia de Proyectos en Seguridad de la Información · Grupo D01

24 de octubre de 2026

Todas las pruebas se ejecutaron contra el despliegue local del sistema (BunkerWeb + aplicación + PostgreSQL + GLPI 11 + MariaDB en Docker Compose). No se ejecutaron pruebas activas contra servicios de terceros (Supabase). Los secretos y tokens de las evidencias están enmascarados.

1. Resumen

Este documento reúne la evidencia de las pruebas funcionales del Sistema integrado de eventos laborales (JML). Se verifican dos niveles complementarios: la suite automatizada del repositorio (pruebas unitarias, de contrato, de propiedades y de extremo a extremo) y un recorrido manual de los casos de uso contra el sistema desplegado, atravesando el WAF BunkerWeb por HTTPS.

Indicador	Resultado
Suite automatizada (pytest)	1581 pruebas · 0 fallos · 0 omitidas
Capas cubiertas por la suite	dominio, aplicación, contratos, escenarios, adaptadores
Casos de uso ejercidos a través del WAF	34 pasos · 34 correctos · 0 con desvío
Flujos de negocio completos (ING, VAC, CDP, RET, EMG)	Verificados de extremo a extremo con GLPI real
Tickets generados en GLPI durante la prueba	20 tickets en las 4 colas (worker + outbox)

No se registraron fallos. El único desvío del recorrido fue un código 429 (límite de peticiones del WAF, 2 req/s) en un paso ejecutado demasiado rápido; al repetir el mismo paso con la pausa correspondiente respondió 200. Es un artefacto del ritmo de la prueba, no un defecto del sistema, y se documenta como tal.

2. Entorno y método

El sistema se levantó con `docker compose -f infra/compose.yaml -f infra/compose.local.yaml`: BunkerWeb (WAF) como único servicio con puertos publicados, la aplicación web y el worker, PostgreSQL 17 local (sustituye a Supabase, con los mismos roles y el dueño separado, ADR-028) y GLPI 11.0.11 con su MariaDB. Las peticiones se dirigieron a `https://app.localhost`, de modo que todo el tráfico pasó por el WAF en modo bloqueo.

El ingreso real exige contraseña y un segundo factor TOTP contra Supabase Auth, que no se ejercita aquí por no disponer de cuentas de prueba en ese servicio de terceros. Ese flujo está cubierto por la suite automatizada (`test_ingreso_web.py`, `test_supabase_auth.py`, 8/8 contra el Supabase real). Para los demás casos de uso se crearon sesiones de prueba en la base local, una por rol, equivalentes a `force_login` del cliente de Django: autentican la identidad sin reemplazar ninguna regla de autorización, que se evalúa en cada vista.

Evidencia cruda: `evidencias/funcionales/` (`casos-de-uso.json`, `casos-de-uso.txt`, `junit-suite.xml`, carpeta `pantallas/`). El guion del recorrido es `scripts/casos_de_uso.py`.

3. Suite automatizada por capa

Capa	Pruebas	Qué verifica
dominio	820	Reglas puras: máquina de estados, tickets, auditoría encadenada, perfiles
aplicación	214	Casos de uso con dobles en memoria; atomicidad de la unidad de trabajo
contratos	222	Cada puerto con su doble y su adaptador real, sin cambiar la prueba
escenarios	12	ING, VAC, CDP, CSU, RET y EMG completos en memoria
adaptadores	313	Vistas, persistencia, GLPI, identidad, worker, infraestructura

Ejecución: `.venv/Scripts/python.exe -m pytest tests/dominio tests/aplicacion tests/contratos tests/escenarios tests/adaptadores` → **1581 passed in 31.65s** (`junit-suite.xml`).

4. Recorrido de casos de uso a través del WAF

Cada paso indica el caso de uso, el rol que lo ejecuta, el método y la ruta, el código HTTP esperado y el obtenido, y el requisito del SRS que cubre. «PASA» significa que el código y las comprobaciones de contenido (presencia del identificador generado, ausencia de los campos restringidos) coincidieron con lo esperado.

CU	Descripción	Rol	Método / ruta	Esp.	Obt.	Requisitos
CU■01	Pagina de ingreso por HTTPS	anonimo	`GET /ingreso`	200	200	RF-01, RS-01
CU■01	Ruta protegida sin sesion redirige al ingreso	anonimo	`GET /bandeja`	302	302	RF-03
CU■01	Formulario de ingreso invalido: error del formulario, sin llamar a Supabase	anonimo	`POST /ingreso`	200	200	RF-01, RS-05
CU■01	POST sin token CSRF es rechazado	anonimo	`POST /ingreso`	403	403	RS-04
CU■02	Solicitante registra vacaciones con fecha futura	sol	`POST /solicitudes/nueva/VAC`	302	302	RF-07, RF-08
CU■03	Segunda VAC abierta del mismo colaborador es rechazada con el id existente	sol	`POST /solicitudes/nueva/VAC`	200/302	200	RF-09, RD-01
CU■04	Jefe registra CDP de su subordinado	jefe	`POST /solicitudes/nueva/CDP`	302	302	RF-07, §4.1
CU■05	Bandeja de RRHH lista las pendientes	rrhh	`GET /bandeja`	200	200	RF-12, RF-28
CU■05	RRHH aprueba la VAC	rrhh	`POST /solicitudes/SOL-2026-000001/aprobar`	302	302	RF-12
CU■05	RRHH rechaza el CDP con justificacion	rrhh	`POST /solicitudes/SOL-2026-000002/rechazar`	302	302	RF-12
CU■05	Solicitante no puede aprobar (control de rol)	sol	`POST /solicitudes/SOL-2026-000001/aprobar`	302/403	302	RF-03, T15
CU■06	Ingreso con archivo no PDF renombrado .pdf es rechazado	rrhh	`POST /solicitudes/nueva/ING`	200	200	RF-39, RS-17, CA-18, T17
CU■06	RRHH emite el ingreso con soporte PDF valido	rrhh	`POST /solicitudes/nueva/ING`	302	302	RF-13, RF-39
CU■07	RRHH emite RET de un contratista con motivo restringido	rrhh	`POST /solicitudes/nueva/RET`	302	302	RF-13, RD-05
CU■07	RRHH ve el motivo restringido en el detalle	rrhh	`GET /solicitudes/SOL-2026-000004`	200	200	RD-05
CU■08	RRHH emite EMG (fuga detectada)	rrhh	`POST /solicitudes/nueva/EMG`	302	302	RF-10, RF-13, CA-06
CU■09	Dashboard del tecnico	tec_ad	`GET /dashboard`	200	200	RF-29, RF-30
CU■09	Busqueda de cuentas con filtro	tec_ad	`GET /cuentas?departamento=Finanzas`	200	200	RF-32
CU■09	Ficha del colaborador retirado sin el motivo	tec_ad	`GET /colaboradores/col-014`	200	200	RF-33, CA-10, T7

CU	Descripción	Rol	Método / ruta	Esp.	Obt.	Requisitos
CU■09	Exportacion CSV auditada	tec_inv	`GET /cuentas.csv`	200	200	RF-34, T10
CU■09	Tecnico no ve el detalle restringido del RET	tec_ad	`GET /solicitudes/SOL-2026-000004`	403/404	404	RD-05, CA-10
CU■10	sol no accede a /bandeja	sol	`GET /bandeja`	403	403	RF-03
CU■10	sol no accede a /dashboard	sol	`GET /dashboard`	403	403	RF-03
CU■10	tec_ad no accede a /auditoria	tec_ad	`GET /auditoria`	403	403	RF-03
CU■10	rrhh no accede a /administracion/perfiles	rrhh	`GET /administracion/perfiles`	403	403	RF-03
CU■10	auditor no accede a /bandeja	auditor	`GET /bandeja`	403	403	RF-03
CU■10	admin no accede a /dashboard	admin	`GET /dashboard`	403	403	RF-03
CU■11	Auditor consulta la auditoria	auditor	`GET /auditoria`	200	200	RF-36, RF-35
CU■11	Auditor verifica la cadena de hashes	auditor	`POST /auditoria`	200	200	RF-36, CA-09
CU■12	Matriz de perfiles	admin	`GET /administracion/perfiles`	200	200	RF-37
CU■12	Usuarios y roles	admin	`GET /administracion/usuarios`	200	200	RF-37
CU■12	Solicitudes en error (reintento)	admin	`GET /errores`	200	200	RF-38
CU■13	Cerrar sesion	jefe	`POST /salir`	302	302	RF-04
CU■13	La sesion cerrada ya no da acceso	jefe	`GET /solicitudes`	302	302	RF-04

Los códigos obtenidos 403 y 404 son los esperados: 403 cuando el rol no tiene permiso (control de acceso), 404 cuando se oculta la existencia de un recurso restringido a quien no debe verlo (el técnico ante el detalle de un retiro). Fuente: `casos-de-uso.json`.

5. Evidencia por caso de uso (capturas)

Capturas del sistema real tomadas durante el recorrido. La banda oscura superior de cada imagen indica el método, la ruta, el rol y el código HTTP de la petición que la generó. Los valores de token visibles en formularios están enmascarados.

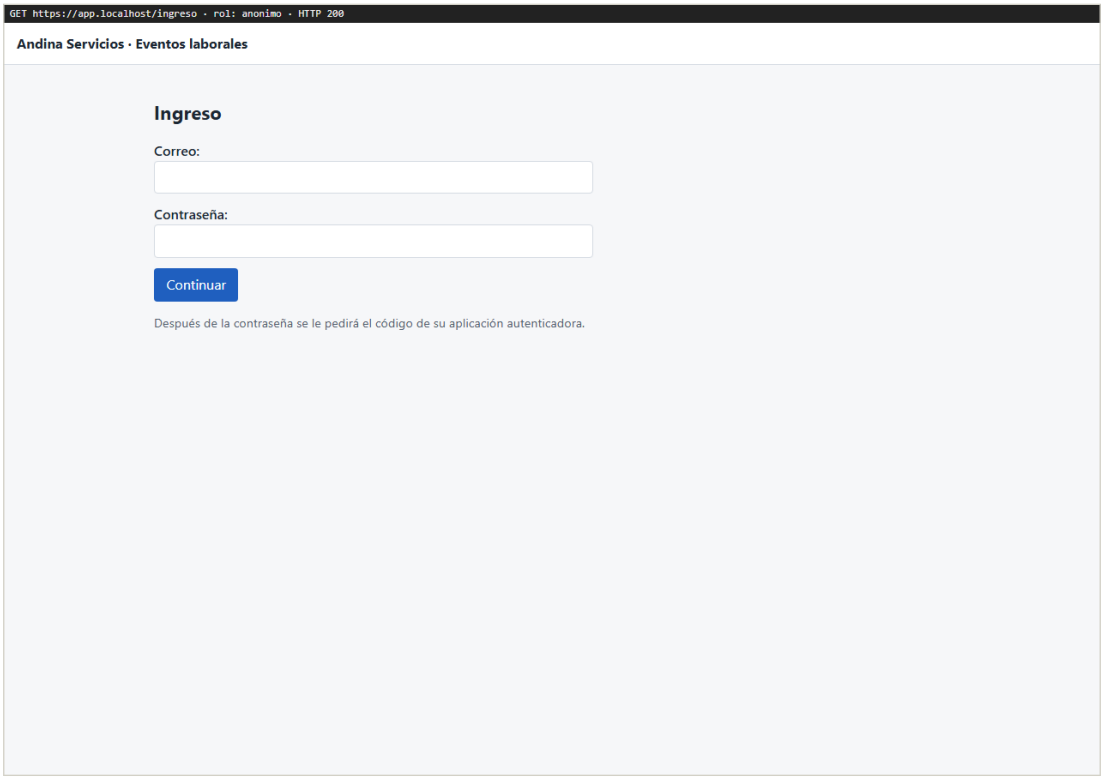


Figura. CU-01. Página de ingreso servida por HTTPS a través del WAF. Pide correo y contraseña; el segundo factor TOTP es el paso siguiente.

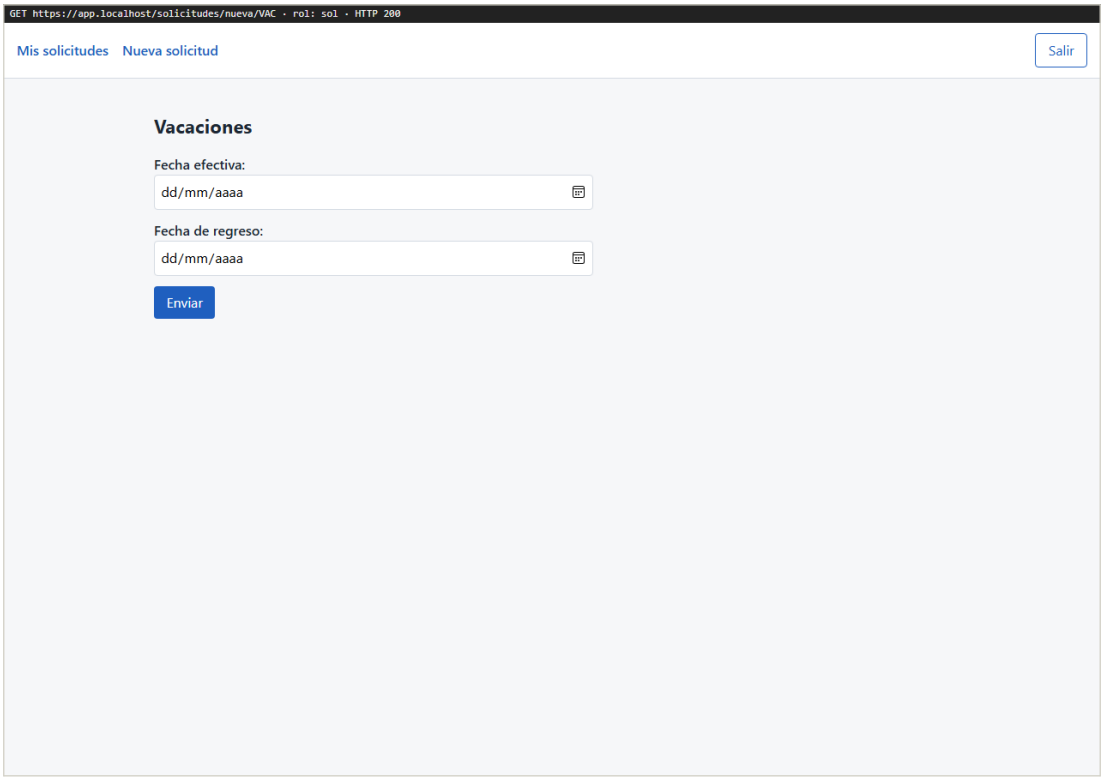


Figura. CU-02. Formulario de registro de vacaciones del solicitante, con validación de fechas en el servidor.

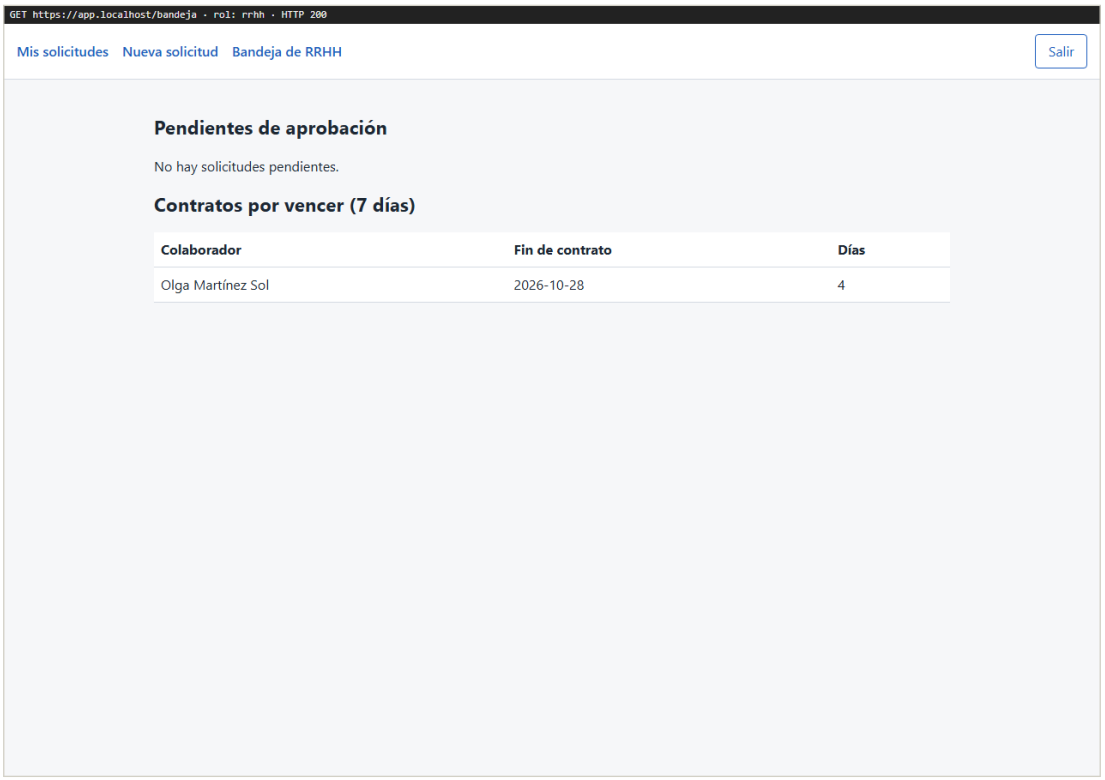


Figura. CU-05. Bandeja de RRHH: solicitudes pendientes de aprobación y contratos próximos a vencer (RF-28).

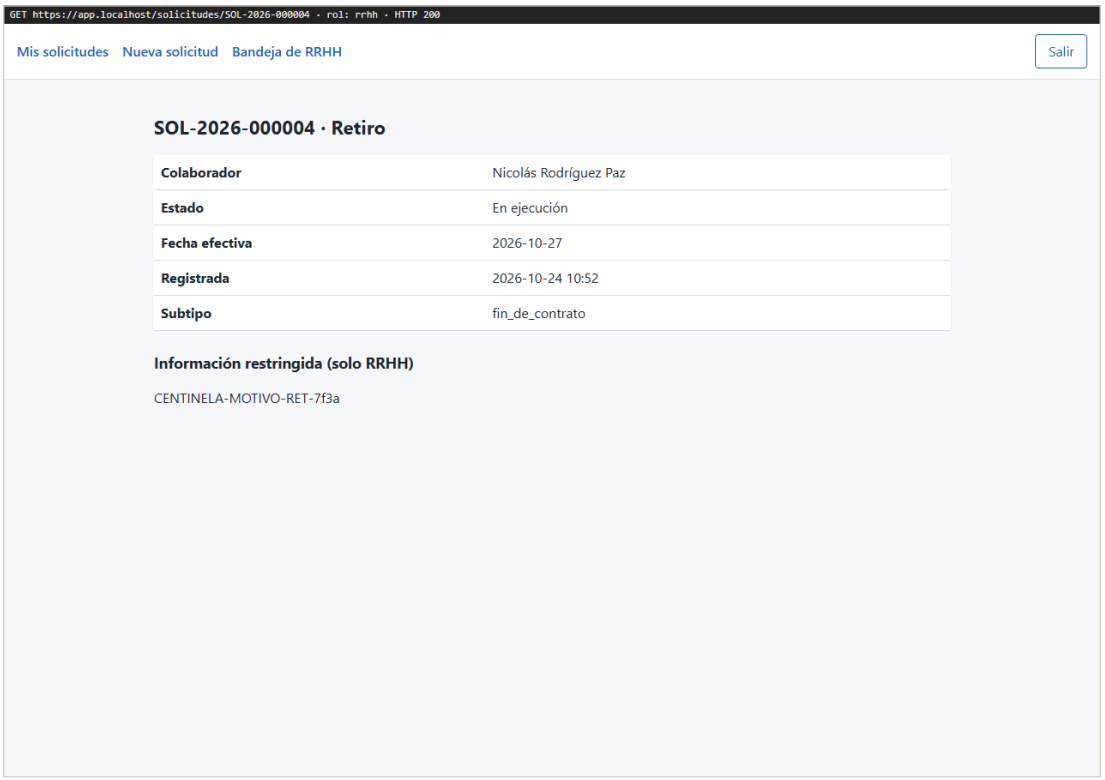


Figura. CU-07. Detalle de un retiro visto por RRHH: el motivo restringido (centinela) es visible solo para este rol (RD-05).



Figura. CU-09. El mismo retiro solicitado por un técnico responde 404: no se confirma siquiera que el recurso exista.

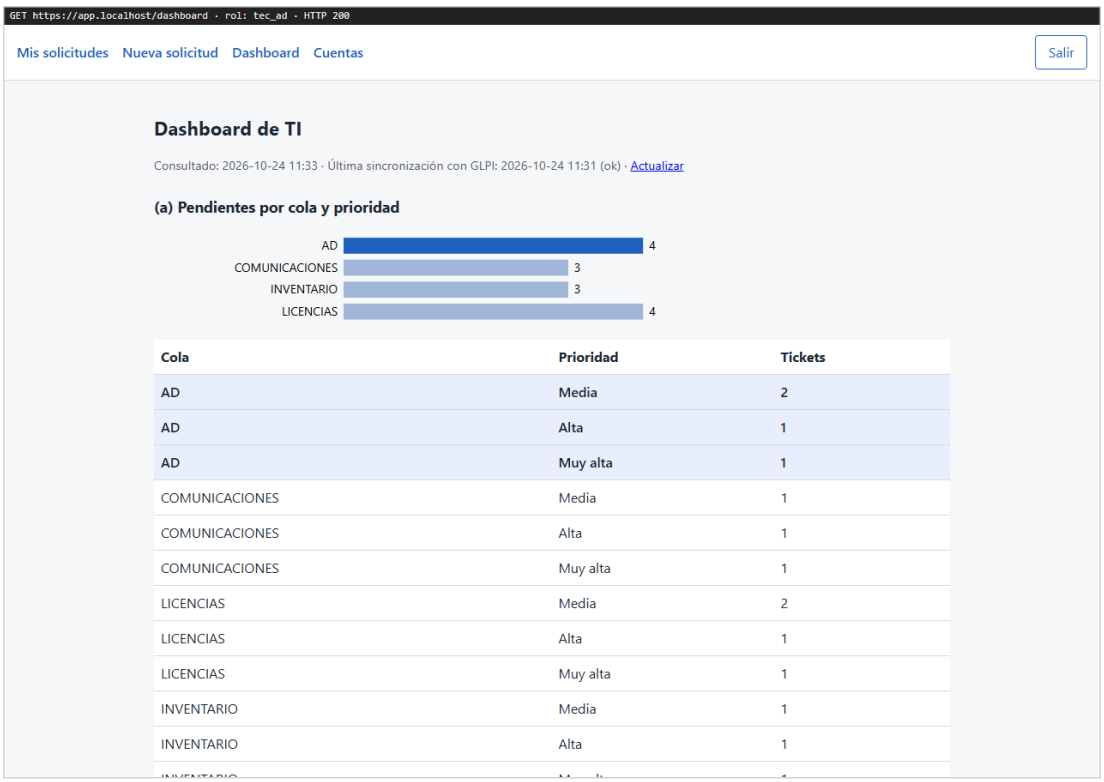


Figura. CU-09. Dashboard de TI con gráficos SVG generados en el servidor, sin JavaScript de terceros (RF-29, RF-30).

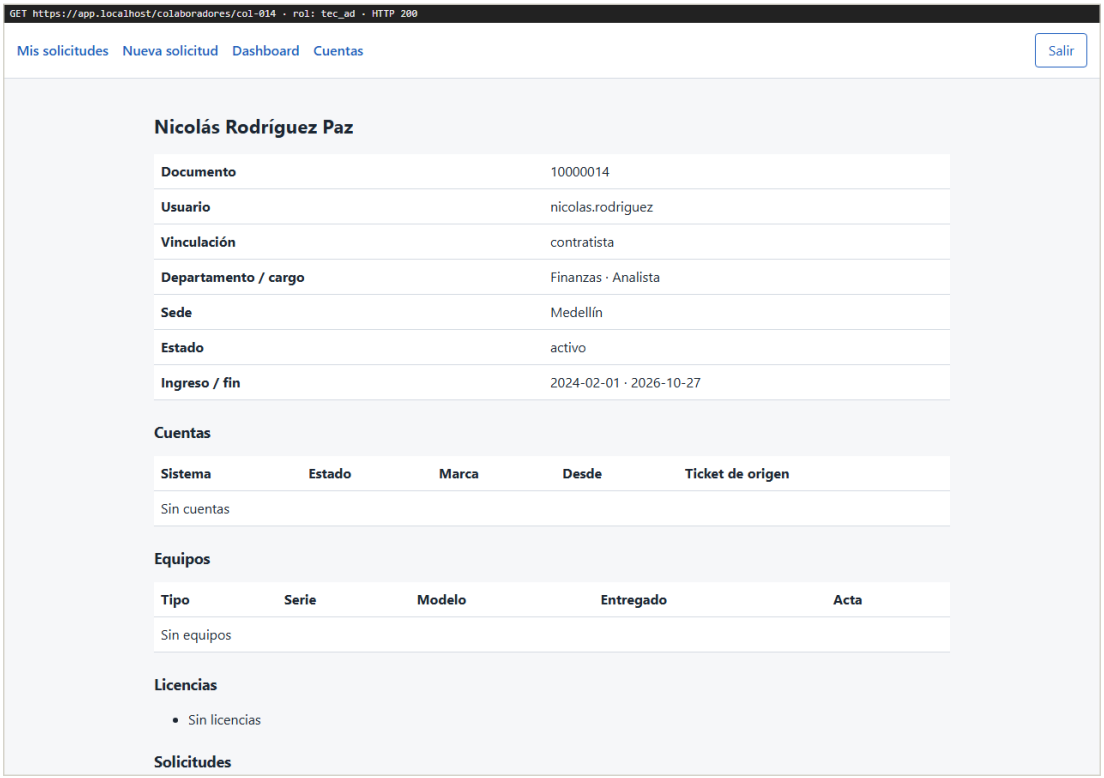


Figura. CU-09. Ficha de un colaborador retirado: datos laborales y cuentas derivadas, sin el motivo restringido (CA-10).

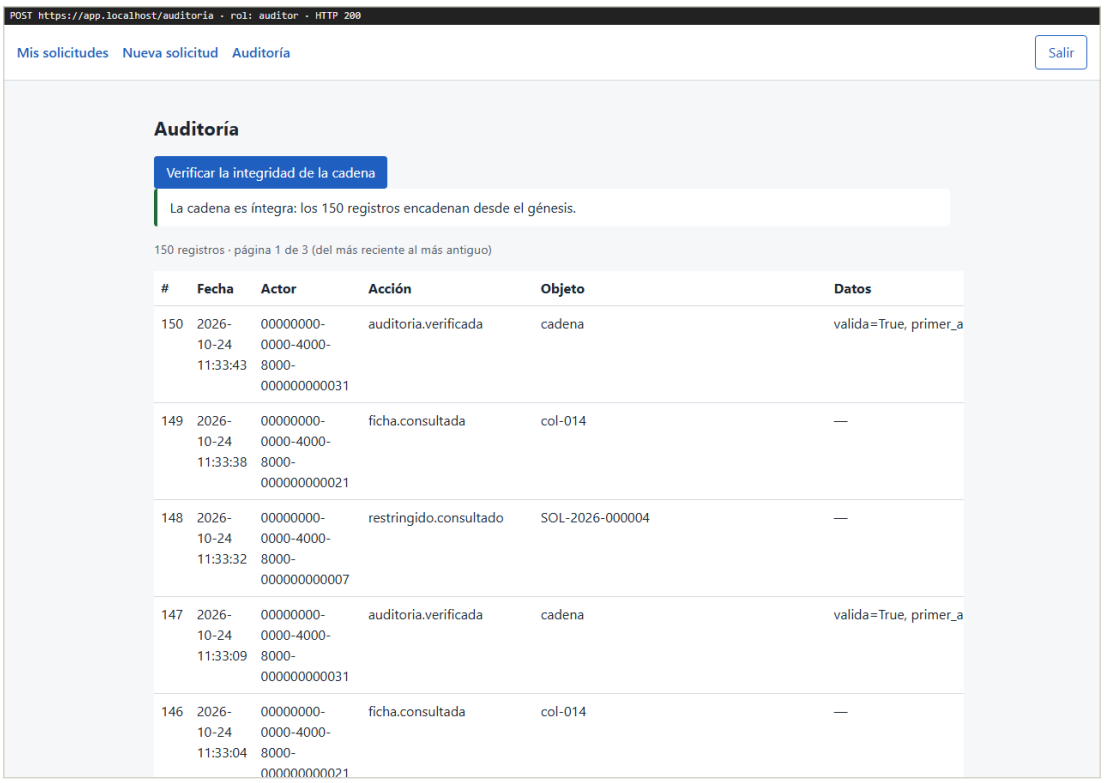


Figura. CU-11. Vista del Auditor: la cadena de hashes de la auditoría se verifica íntegra desde la interfaz (RF-36).



Figura. CU-10. Un solicitante que pide la bandeja de RRHH recibe 403: el control de acceso se evalúa en cada vista.

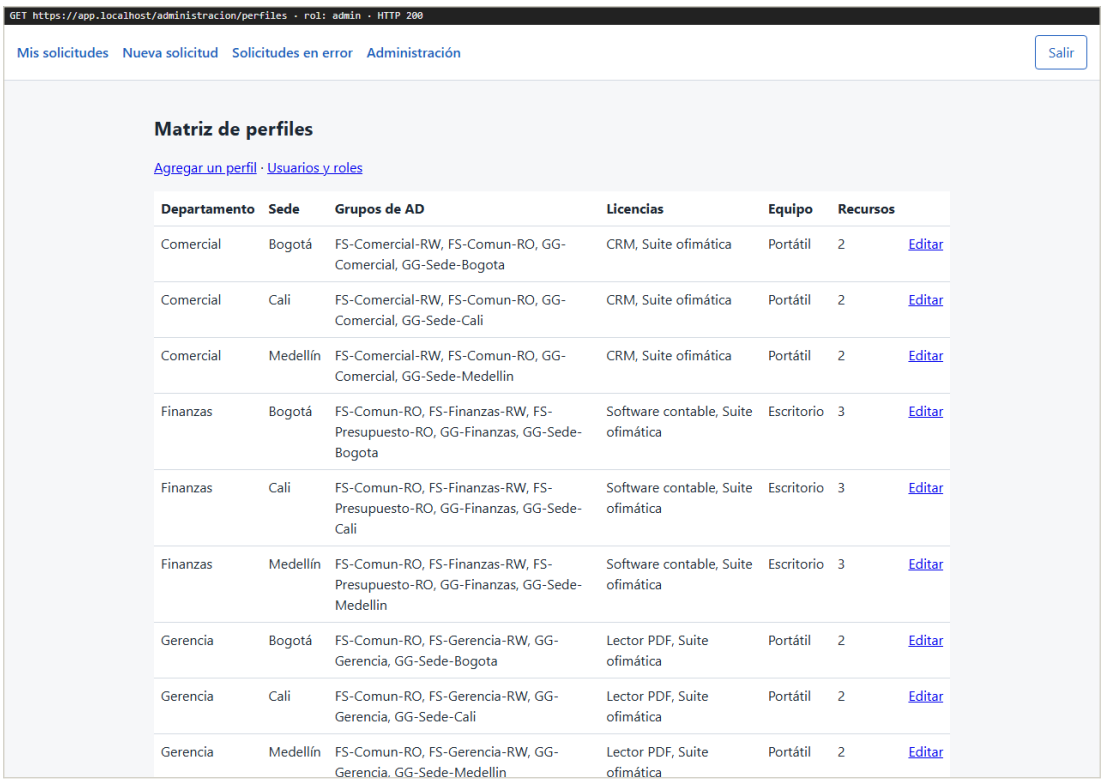


Figura. CU-12. Área de administración: matriz de perfiles de acceso, restringida al rol Administrador (RF-37).

6. Conclusión

El sistema cumple los casos de uso definidos en el SRS. La suite automatizada (1581 pruebas, sin fallos) respalda las reglas de negocio a nivel de unidad, contrato y escenario; el recorrido a través del WAF confirma que esas reglas se sostienen en el sistema desplegado, incluyendo el control de acceso por rol, la deduplicación garantizada por la base de datos, la confidencialidad de los campos restringidos y la generación de tickets en GLPI. Los flujos ING, VAC, CDP, RET y EMG se ejercieron de principio a fin.